

南开大学

信息对抗技术课程实验报告

实验八：使用 L0phtCrack 破解 Windows 口

令实验



学 院 密码与网络空间安全学院
专 业 信息安全、法学双学位班
学 号 2313815
姓 名 段俊宇
班 级 信息安全、法学双学位班

一、实验目的

1. 使用 L0phtCrack 破解 windows 口令。
2. 熟悉 Windows 系统口令的存储机制（SAM 文件、NTLM 哈希），了解哈希破解的基本逻辑。
3. 认识弱口令的安全风险，树立网络安全意识，掌握 Windows 系统口令安全防护方法。
4. 严格遵守网络安全法律法规，仅对个人拥有权限的 Windows 设备进行测试，杜绝未经授权的破解操作。

二、实验原理

L0phtCrack 是一款网络管理员的必备的工具，它可以用来检测 Windows、UNIX 用户是否使用了不安全的密码，同样也是最好、最快的 WinNT/2000/XP/UNIX 管理员账号密码破解工具。事实证明，简单的或容易遭受破解的管理员密码是最大的安全威胁之一，因为攻击者往往以合法的身份登陆计算机系统而不被察觉。

其实现方法有以下几种：

（1）字典攻击法，最快也是最简单的方法。L0phtCrack 将字典中的词逐个与口令 hash 表中的词作比较。当发现匹配的词时，显示结果，即用户口令。L0phtCrack 自带一个小型词库。如果需要其它字典资源可以从互联网上获得。这种破解的方法，使用的字典的容量越大，破解的结果越好。

（2）Hybrid。它是建立在字典破解的基础上的。现在许多用户选择口令不再单单只是由字母组成的，添加了符号和数字的字符串作为口令。这类口令是复杂了一些，但通过口令过滤器和一些方法，破解它也不是很困难，Hybrid 就能快速地对这类口令进行破解。

（3）“暴力破解”法，最有效的一种破解方式。按道理说真正复杂的口令，用现在的硬件设备是无法破解的。但现在所谓复杂的口令一般都能被破解，只是时间长短的问题。且破解口令时间远远小于管理员设置的口令有效期。使用这种方法也能了解一个口令的安全使用期限。

开始破解过程，L0phtCrack 首先需要检索口令 hash 列表。如果有管理权限，可以使用 Tools Dump Passwords from Registry 命令在 L0phtCrack

菜单上检索 hash 表。可以从本地机上或是允许访问的远程机倒出口令 hash 列表。在注册表对话框中的 Dump Passwords 输入 NT 机器名，或 IP 地址，点击 OK。用户名和密码下载到 L0phtCrack 中。对口令列表的检索结束之后，开始执行口令过程。

第二种访问 hash 列表的方法为通过文件系统。因为操作系统对 SAM 文件进行了加密，口令存储在该文件系统中。当操作系统在运行过程中，是不可能从文件系统中得到任何信息的。有时候，文件系统的备份被保存在磁盘或一个加密的 repair 磁盘上或是在系统硬件的 repair 目录上。同时，其它的操作系统（如 DOS 系统）可以从软盘启动，口令 hash 能直接从文件系统得到。如果你能对计算机进行物理访问，这种方法很有用。

最后一种方法为通过网络。一台机器中有一个或多个以太网设备对网络进行访问。使用 Tool SMB Packet Capture 命令启动 SMB 包捕获窗口。网络设备能获得任何 SMB 认可的部分。如果你转换网络，你就只能看到本机或连接的机器原有的任务。

当 SMB 认可的任务授权被捕获的时，在 SMB Packet Capture 的窗口显示。内容有：源代码，目的 IP 地址，用户名，SMB 口令，加密 LAMMAN hash 列表和加密 NTLM hash 列表等等。Save Capture 命令保存捕获到的信息，用来破解 hash 表。File Open Password 命令打开捕获的内容。同时，还可以对其它的口令进行捕获和破解。Todd Sabin 发布了一个免费的工具，能在本地导出口令的 hash 列表，如果 SAM 使用的是 SYNKEY 工具进行加密，根据网站上的指导可以对口令的 hash 表进行检索。你可以使用 File Open Password File 命令下载 hash 列表到 L0phtCrack 中。

L0phtCrack 的第一种方法是使用字典攻击。该方法通过使用字典中的词库进行破解工作。将词库中的所有的口令与口令 hash 列表作比较。如果得到了匹配的词，则破解成功。

开始破解的过程：选择菜单上的 Tools Run Crack。默认的顺序是字典攻击，hybrid 攻击，暴力破解。通常在使用了这三种方法之后，L0phtCrack 大都能成功的获得口令。如果你愿意也可以在 Tools Option 对话框中定义破解攻击的具体步骤。L0phtCrack 窗口显示的状态信息表明，字典攻击成

功的概率和字典中词库的大小成正比例。

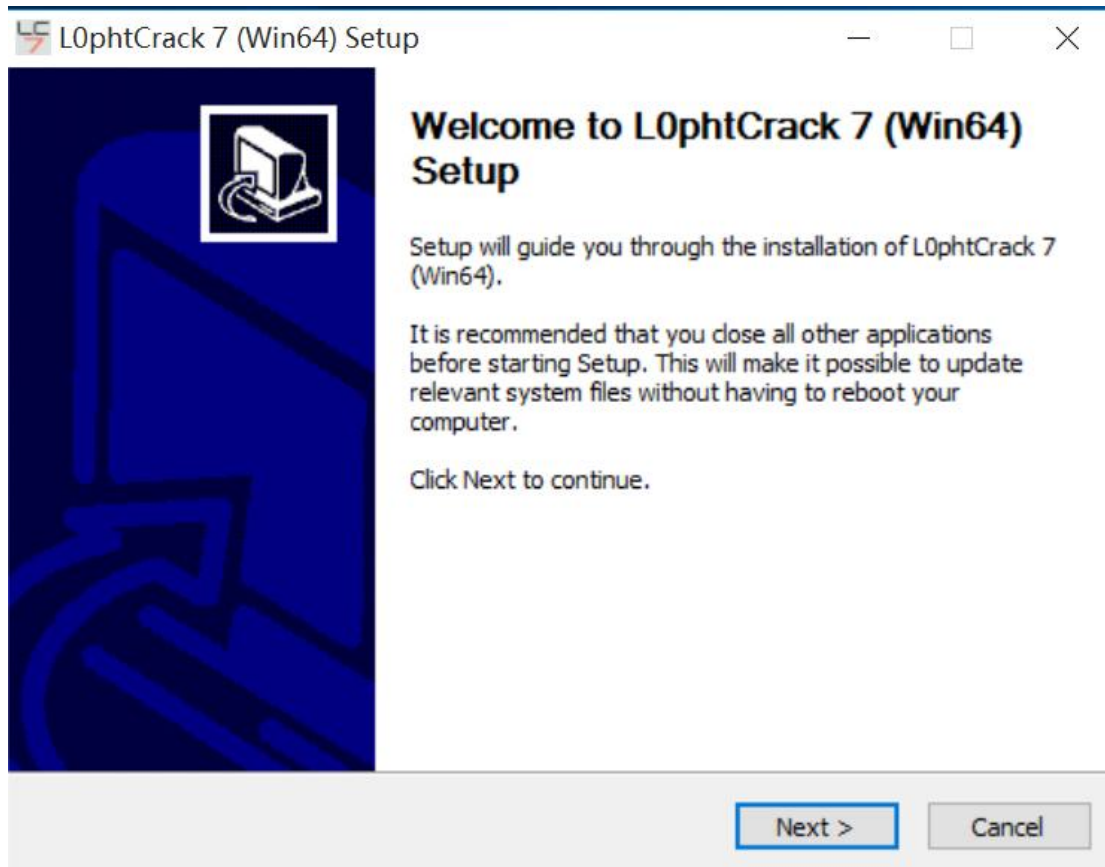
在字典攻击失败后，开始 hybrid 攻击。hybrid 使用简单的模式，用户通过对一般词汇的改变产生的口令进行攻击。L0phtCrack 能智能化地尝试口令的猜测。比如试一试 BOGUS11。许多的用户仅仅在一些原有词的基础上添加了很少的数字或符号，来试图创造一个不可猜测的口令。但 L0phtCrack 能很快猜测出这些口令，而不再需要进行暴力攻击。L0phtCrack 的 Hybrid 的破解方法，使用的默认检验字符或数字的个数是 2。也可以通过 Tools Options 命令来改变该数值。

在字典攻击和 hybrid 攻击失败之后，就是暴力攻击。它可能会消耗相当长的时间，但是这些时间远远小于口令的有效期。因此这些口令在暴力攻击面前显得格外的脆弱。可以通过使用 Tool Option 命令改变字符数字的设置。默认的设置是尝试所有的数字和字符。

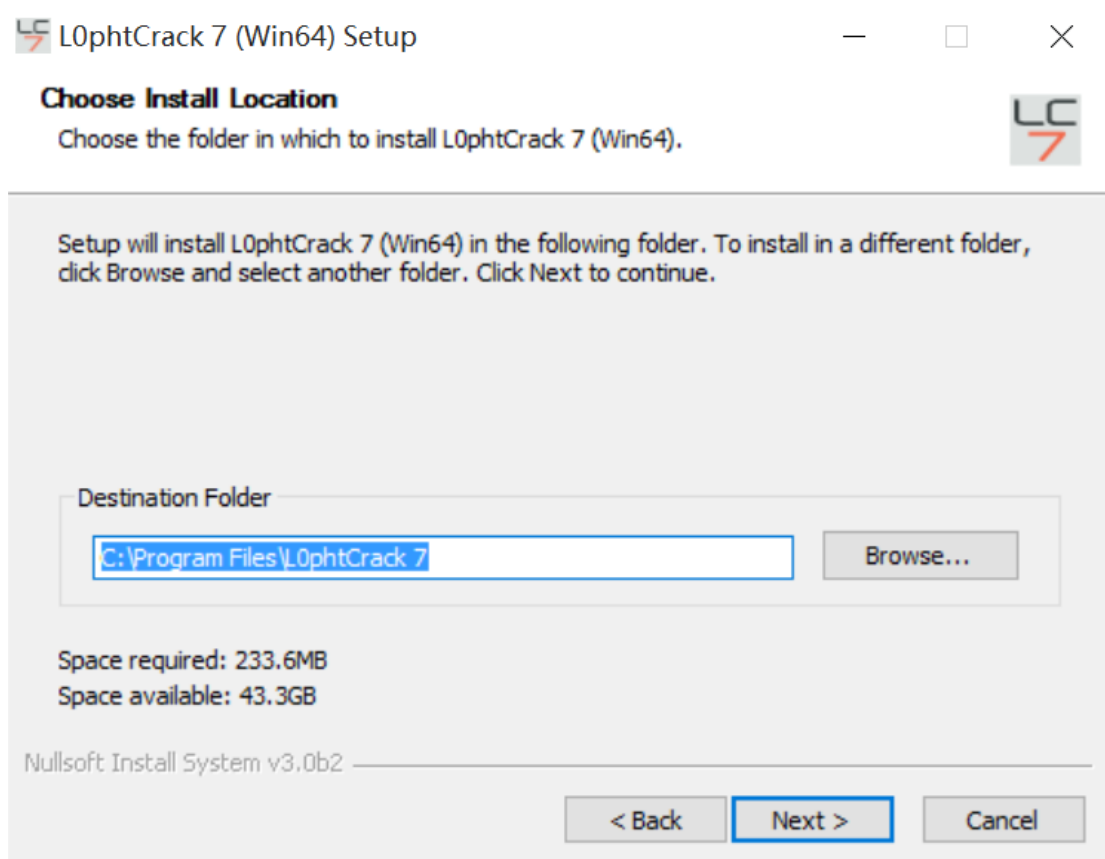
三、实验过程

1. 下载安装 L0phtCrack

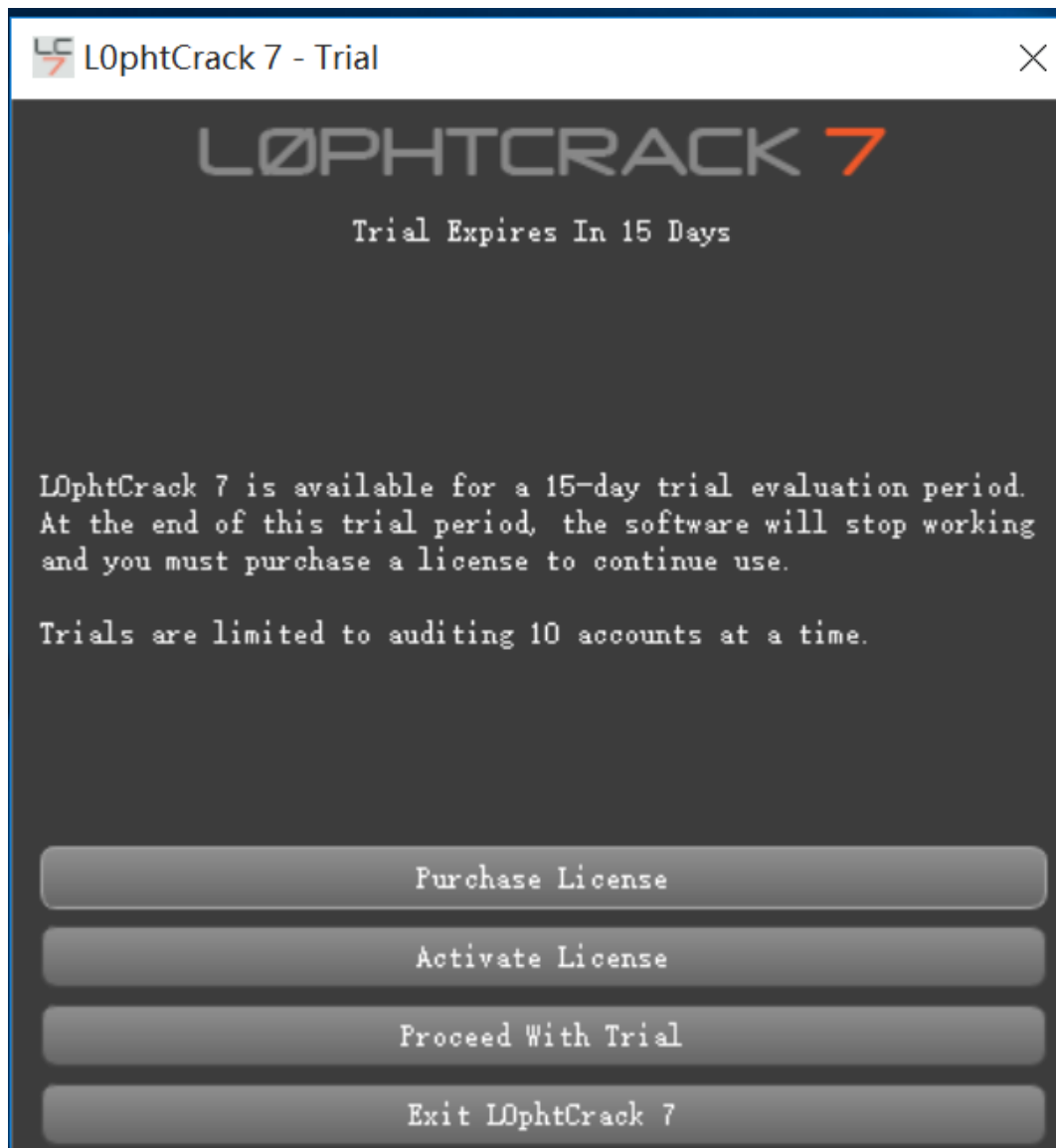
本次实验我使用 Windows 10 虚拟机来完成，首先从网上下载 L0phtCrack 的压缩包并启动安装程序。由于该程序可能被认定为病毒，因此需要暂时关闭 windows defender。

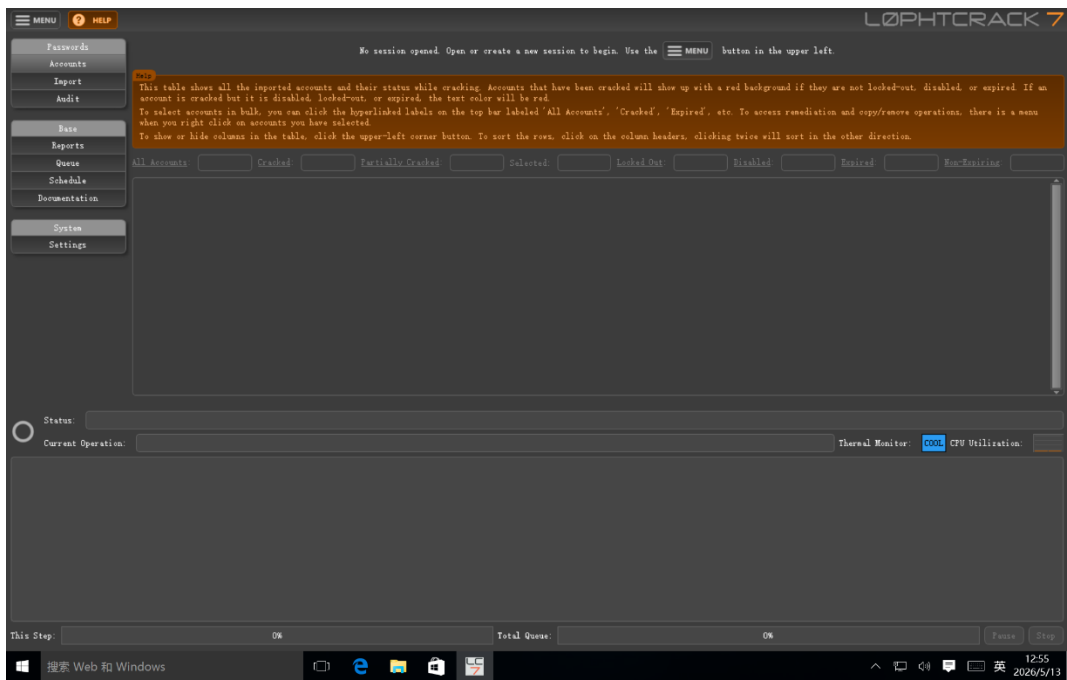


同意协议后选择安装路径，默认即可。



安装完毕后将本地账户的口令设置为 123456, 便于 L0phtCrack 进行爆破, 验证效果。打开该程序, 选择 Proceed With Trial 并进入, 使用试用版完成实验。

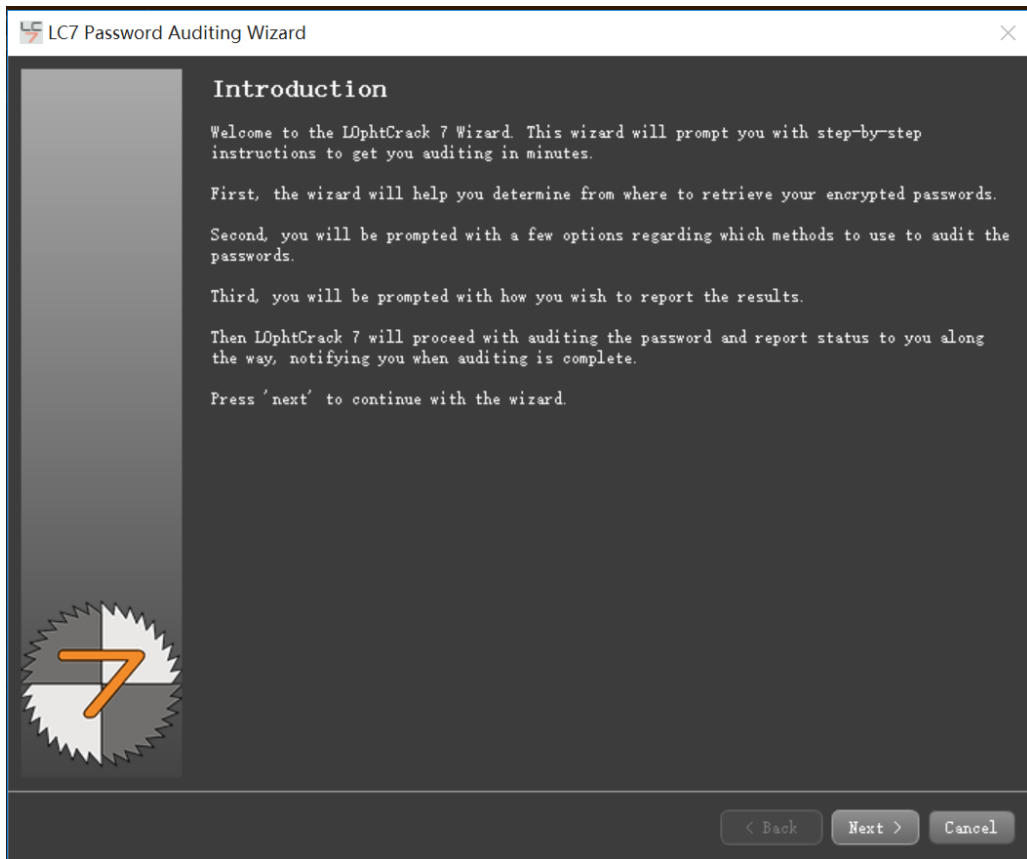




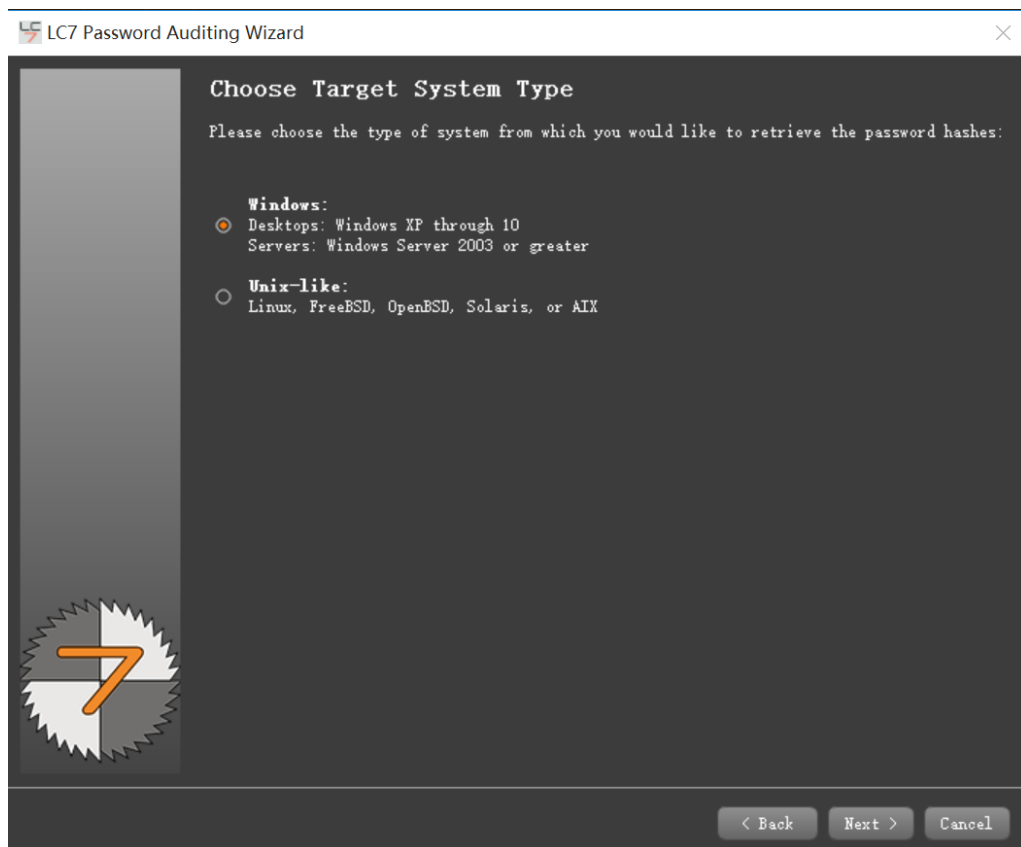
接下来按照提示实现对密码的破解，选择 Password Auditing Wizard 向导程序。



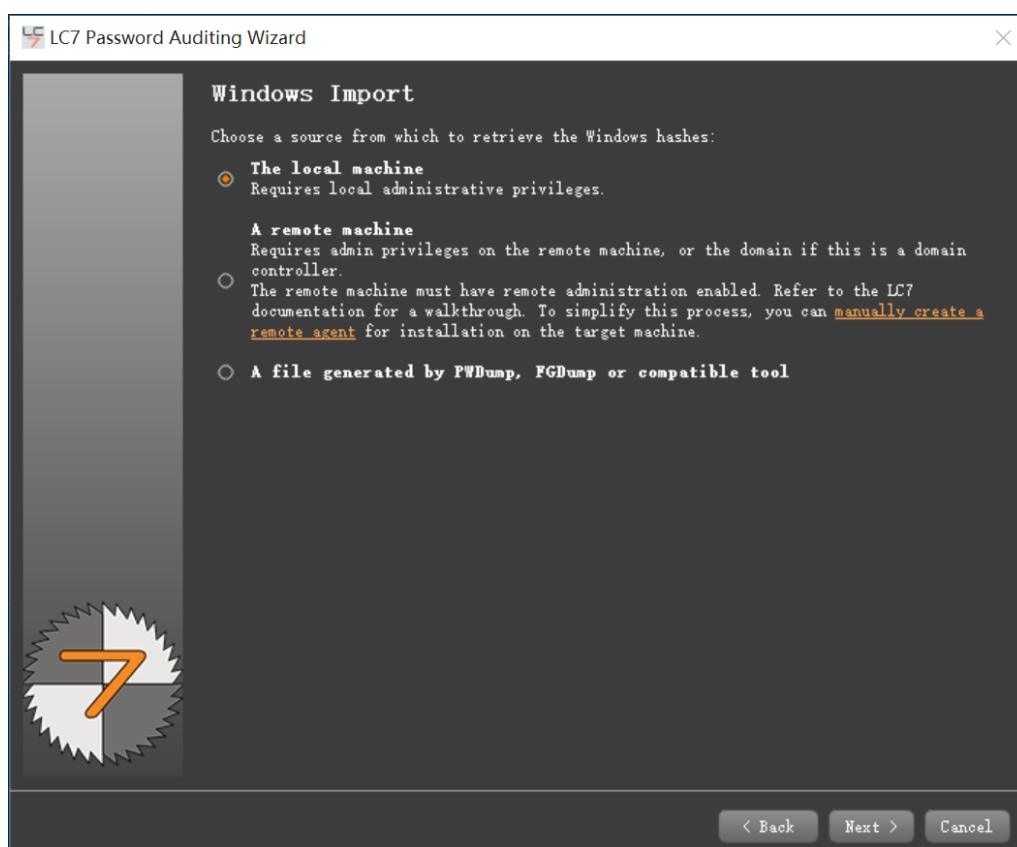
向导程序介绍中说明了接下来需要选择的选项，首先是目标密码的位置，其次是获取密码的方式以及呈现获取结果的方式，最后运行获得密码。



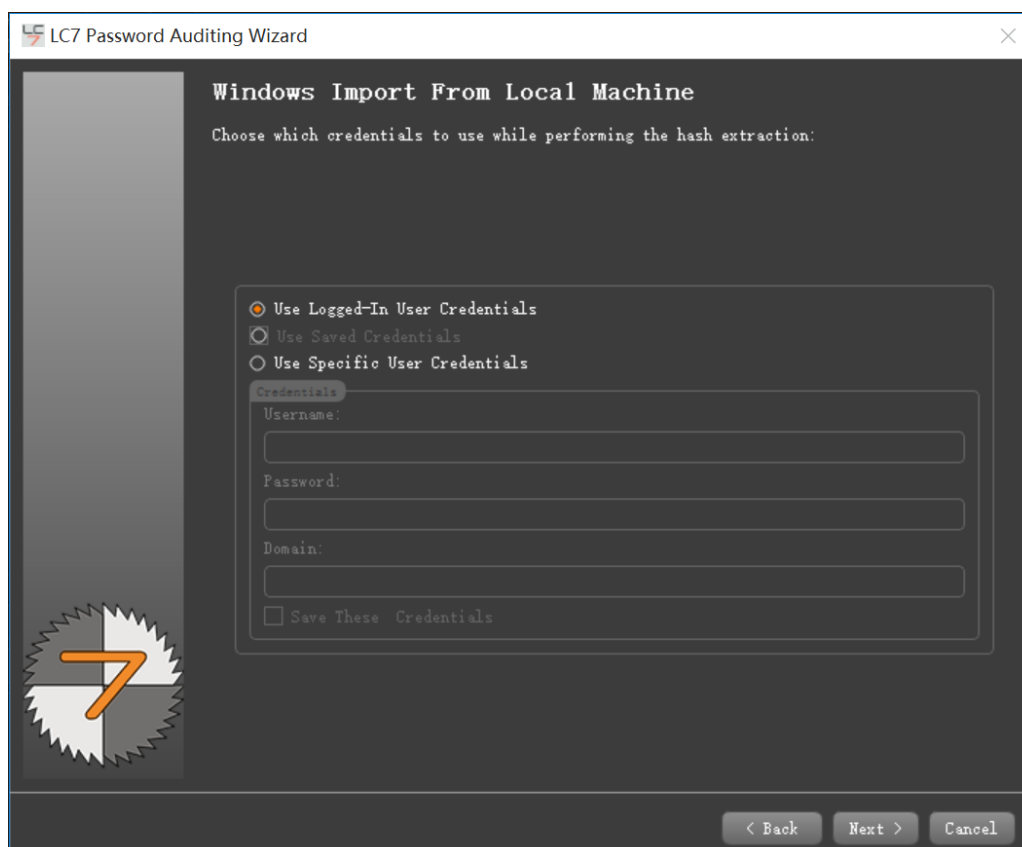
首先选择目标系统 Windows:



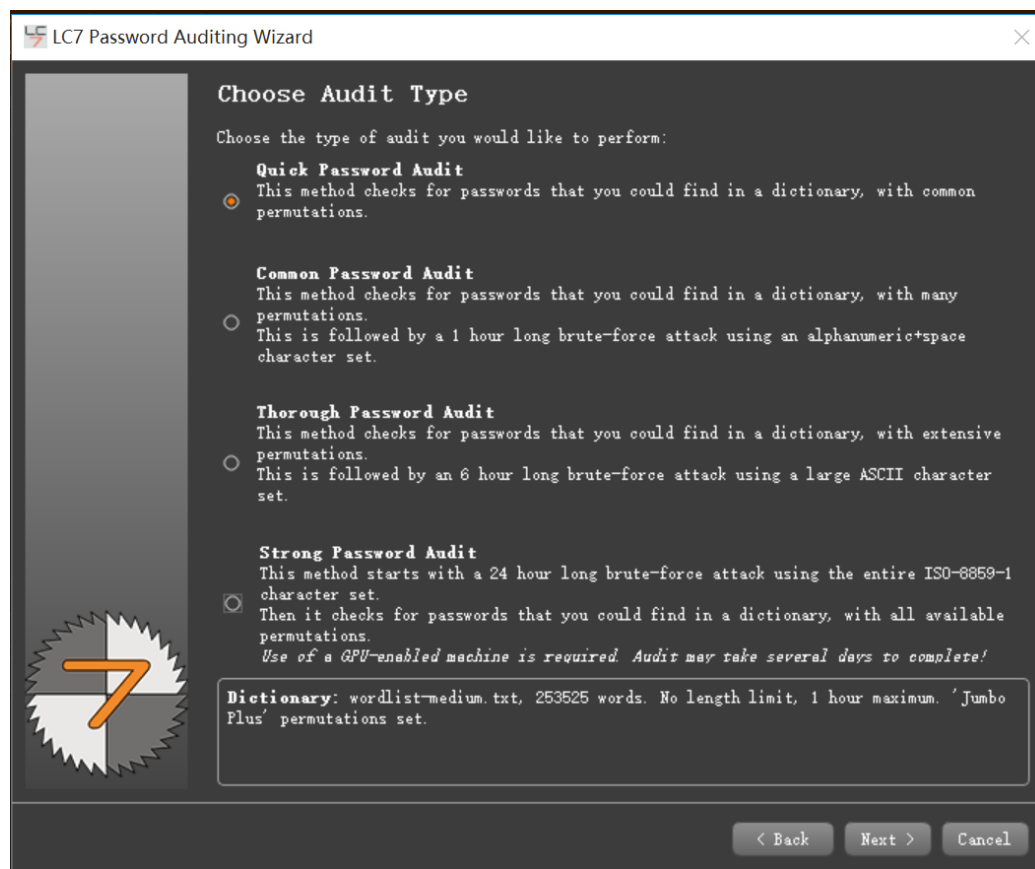
接下来选择导入的主机为 local machine，即本地账户。



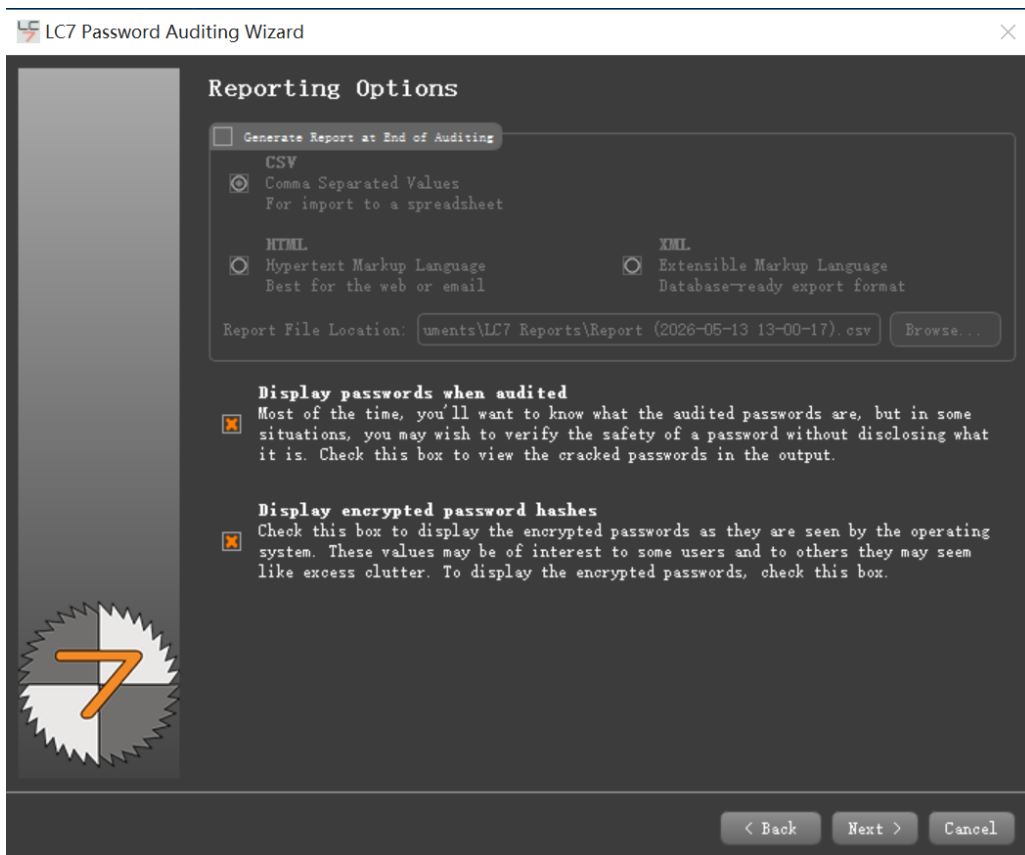
选择 Logged-in User Credentials，即本机中的证书：



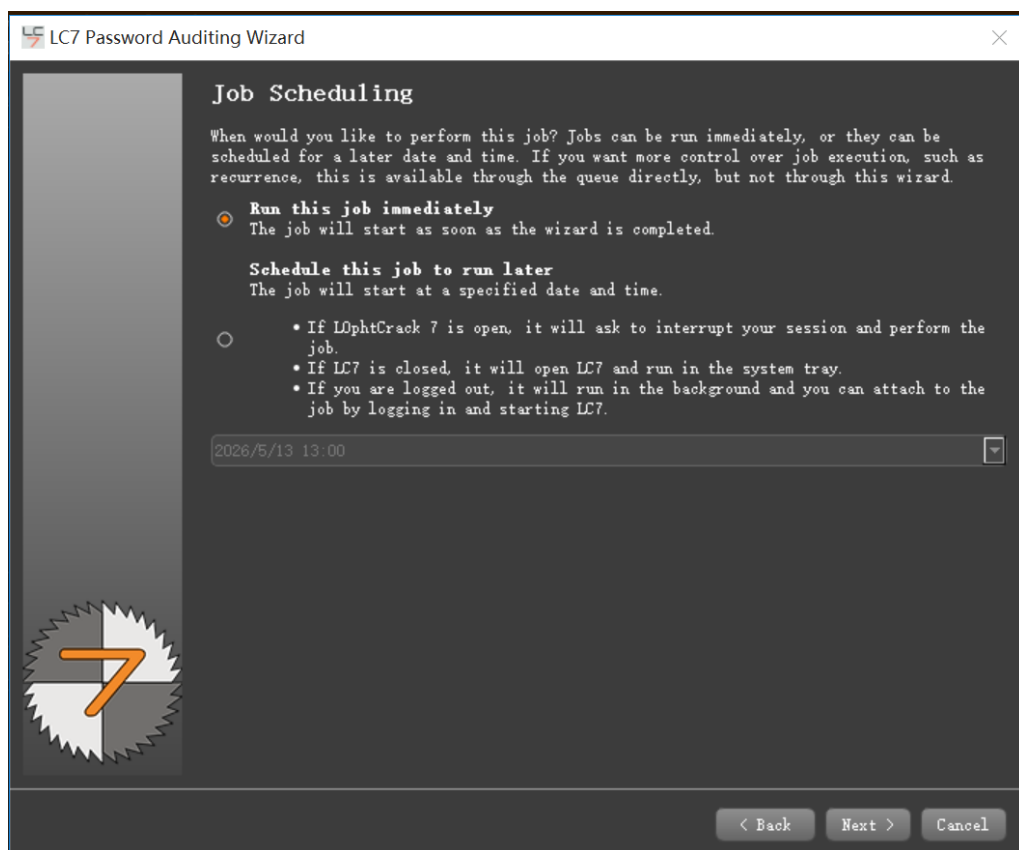
选择获取方式为 Quick Password Audit，由于这种方式速度较快，因此本次实验对其进行测试。



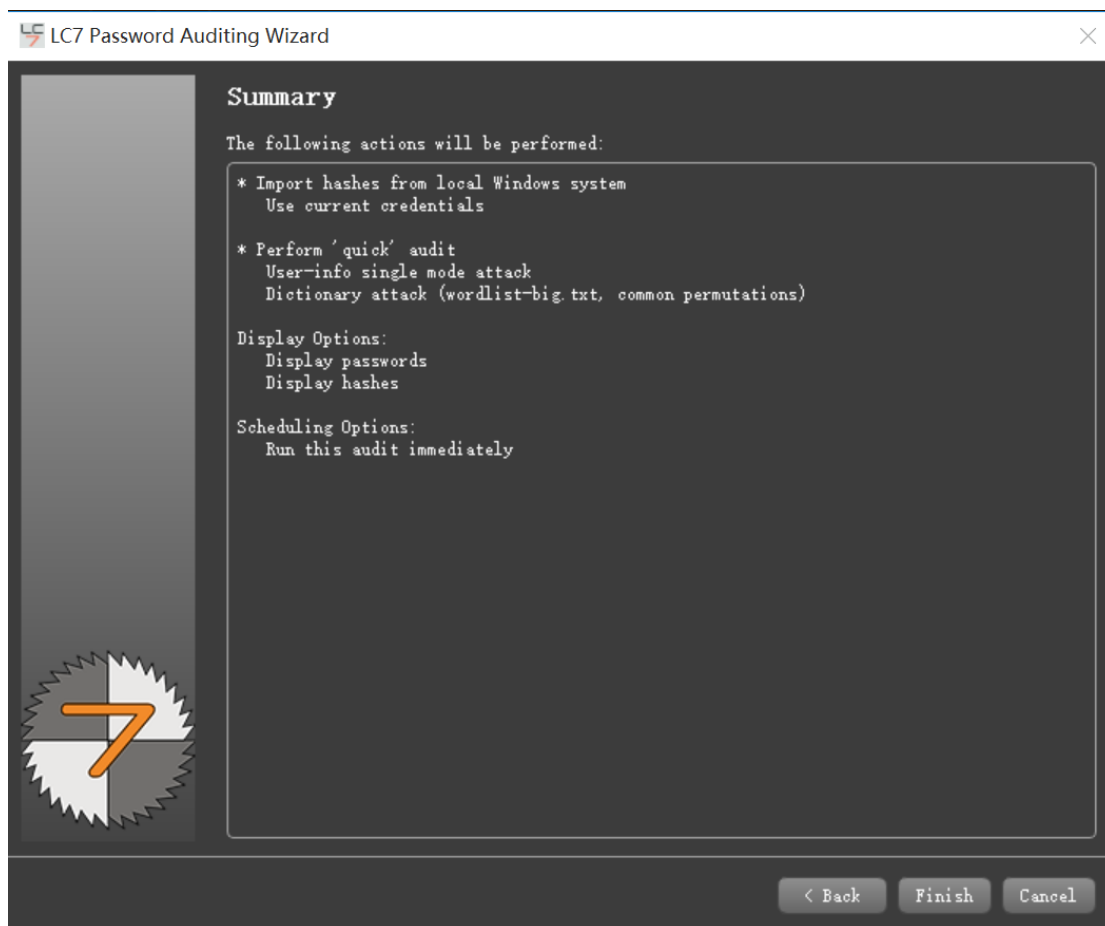
选择结果报告的形式为 Display password when audited & Display encrypted password hashes，也就是呈现密码明文以及对应的哈希值。



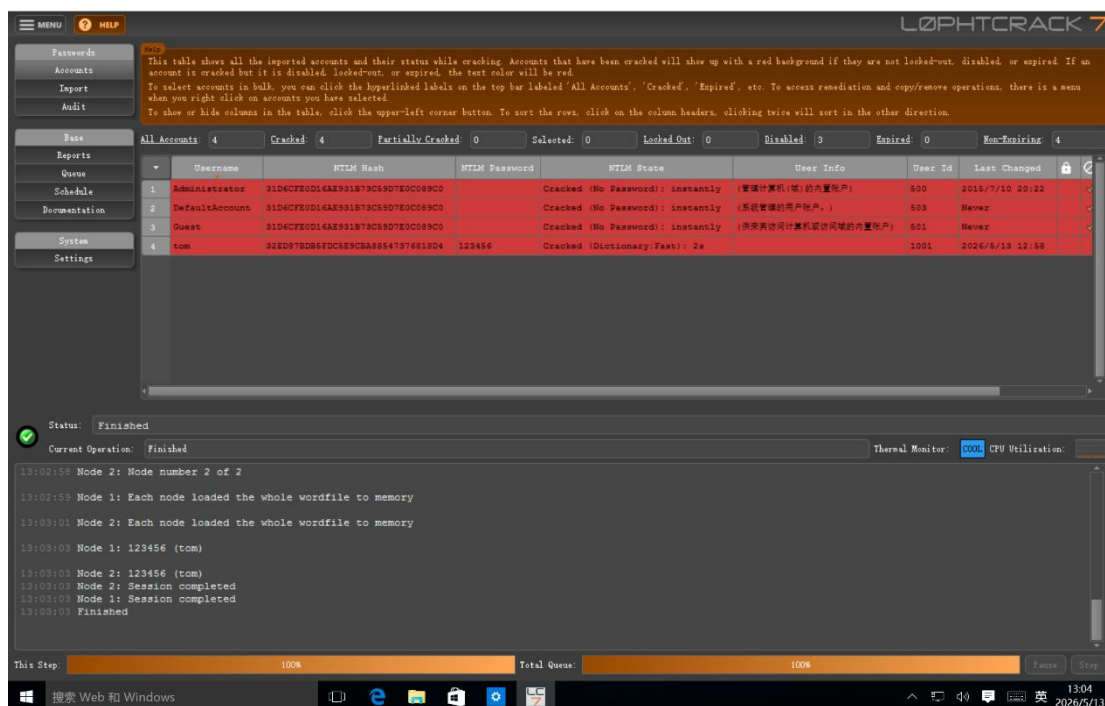
选择立即运行即可：



接下来程序会显示当前选择的所有选项，检查无误后开始破解即可。



运行后发现很快就成功破解出了弱口令 123456:



这说明弱口令极易被破解，即便长度增加，其安全性依然很低。因此

需要使用大小写字母、数字、以及字符的组合，才能够提高安全性。

2. 思考题

- 1) 为什么 L0phtCrack 无法直接读取 SAM 文件，需要通过管理员权限提取哈希值？

SAM (Security Account Manager) 文件是 Windows 存储本地用户账户口令哈希值的保险柜，为了保护这个关键文件，Windows 在其运行期间会对该文件设置独占锁定。通过管理员权限可以从正在运行的系统注册表中，将 SAM 文件里的口令哈希值提取或转储出来。

- 2) 字典攻击和暴力攻击的区别是什么？分别适用于什么场景？

字典攻击使用一个预定义的“字典”文件进行尝试，其中包含常用单词、短语、泄露的密码列表等，破解效率非常高，适用于快速检测常见的弱口令；暴力攻击尝试所有可能的字符组合，直到匹配正确的密码，破解效率很低，适合对未知或高强度的密码进行最终破解。

- 3) 如何提升 Windows 系统口令的安全性？

- 通过组策略强制要求密码满足“复杂性要求”。
- 启用“账户锁定阈值”策略，防止暴力攻击或者字典攻击。

- 4) 除了 L0phtCrack，还有哪些常见的 Windows 口令破解工具？

还有 John the Ripper、Hashcat 等工具能够进行口令破解。

四、实验结论及心得体会

本次实验我使用 L0phtCrack 实现了对账户弱口令的破解，掌握了工具的基本操作和口令破解的核心原理。实验结果表明，弱口令是 Windows 系统的重大安全隐患，极易被哈希破解工具攻破。本次实验让我进一步树立了网络安全合规意识，明确了未经授权破解他人设备口令的违法性。同时，也掌握了 Windows 系统口令的安全防护方法，为后续学习网络安全防护、渗透测试等相关知识奠定了基础。